

Explotación de vulnerabilidad SQL Injection en DVWA

Introducción

En este proyecto se realizó la instalación y configuración de DVWA en una máquina virtual con Debian que se ha utilizado en previos proyectos con el objetivo de identificar y explotar una vulnerabilidad de SQL Injection.

Durante el proceso no solo se ejecutó el ataque, sino que también se resolvieron diversos problemas de configuración relacionados con el servidor web, la base de datos y permisos del sistema.

Problemática encontrada

Durante la instalación y configuración de DVWA se presentaron varias problemáticas que entorpecieron el avance del mismo proyecto que se citan a continuación:

- Error al mover la carpeta del proyecto debido a nombres incorrectos (DVWA-master no existía).
- El archivo comprimido contenía un nombre diferente (digininja-DVWA con un numero), lo que causó confusión inicial.
- Problemas de permisos al editar el archivo config.inc.php. Donde se creo incorrectamente otro archivo llamado config.inc.php.save
- Error "config file not found" debido a nombres incorrectos del archivo de configuración.
- Error 500 en el servidor al intentar crear la base de datos.
- Problemas de conexión con la base de datos:
 - Problemática con el usuario root en la parte de db_user
 - Diferencia entre localhost y 127.0.0.1 en MariaDB.
 - Usuario dvwa mal configurado.
- Error crítico en el nombre de la base de datos (dvma en lugar de dvwa).

Solución implementada

Para resolver los problemas anteriores se realizaron las siguientes acciones, con ayuda de ChatGPT, se fueron implementando varias mecánicas hasta ir descartando una a una hasta que se dio a la solución con los siguientes pasos:

1. Se verificó la correcta descarga y descompresión del proyecto.
2. Se renombró la carpeta correctamente a DVWA dentro de la misma extensión.

3. Se creó la base de datos manualmente en MariaDB.
4. Se creó un usuario específico (dvwa) con permisos completos sobre la base de datos.
5. Se corrigieron los parámetros en el archivo config.inc.php.
6. Se ajustaron permisos del archivo para poder editarlo.
7. Se instalaron extensiones necesarias de PHP (mysqli, gd, etc.).
8. Se reiniciaron los servicios de Apache y MariaDB.
9. Se corrigió el error en el nombre de la base de datos.

Después de estas correcciones, la aplicación logró conectarse correctamente a la base de datos y funcionar sin errores.

Proceso de explotación (SQL Injection)

Una vez configurada la aplicación:

1. Se accedió a DVWA desde el navegador.
2. Se inició sesión con las credenciales por defecto.
3. Se configuró el nivel de seguridad en "Low".
4. Se accedió al módulo de "SQL Injection".
5. Se introdujo el siguiente payload:

`1' OR '1'='1`

6. Se ejecutó la consulta.

Resultado obtenido

La aplicación devolvió todos los registros de la base de datos, incluyendo múltiples usuarios, lo que confirma que la vulnerabilidad fue explotada exitosamente.

Esto demuestra que la aplicación no valida correctamente las entradas del usuario y permite manipular las consultas SQL.

http://localhost/DVWA/vulnerabilities/sqli/?id=1+'+OR+'1'+%3D+'1&Submit=Submit#



DVWA

Vulnerability: SQL Injection

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Authorisation Bypass
Open HTTP Redirect

User ID:

ID: 1 ' OR '1' = '1
First name: admin
Surname: admin

ID: 1 ' OR '1' = '1
First name: Gordon
Surname: Brown

ID: 1 ' OR '1' = '1
First name: Hack
Surname: Me

ID: 1 ' OR '1' = '1
First name: Pablo
Surname: Picasso

ID: 1 ' OR '1' = '1
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/links/SQL_injection

debian@debian: /var/www/html/DVWA/config

Impacto de la vulnerabilidad

La vulnerabilidad de SQL Injection permite:

- Acceso a información sensible
- Enumeración de usuarios
- Posible extracción de contraseñas
- Compromiso total de la base de datos

Se considera una vulnerabilidad crítica.

Recomendaciones

Para mitigar este tipo de vulnerabilidades se recomienda:

- Uso de consultas preparadas (prepared statements)
- Validación y sanitización de entradas
- Uso de ORM
- Aplicar el principio de mínimo privilegio en la base de datos

- Evitar mostrar errores detallados al usuario

Conclusión

Este proyecto permitió comprender de forma práctica cómo funciona una vulnerabilidad de SQL Injection y cómo puede ser explotada en un entorno real.

Además, se reforzaron conocimientos sobre configuración de servidores, bases de datos y resolución de errores, los cuales son fundamentales en el área de ciberseguridad.

La experiencia demuestra la importancia de implementar buenas prácticas de desarrollo seguro para evitar este tipo de vulnerabilidades.